

INTERNATIONAL CYBERSECURITY AND  
DIGITAL FORENSICS ACADEMY

# Week 1 Practical Laboratory

---

## Information Security Governance in Action

*GlobalHealth Connect (GHC) — Executive Governance Simulation*

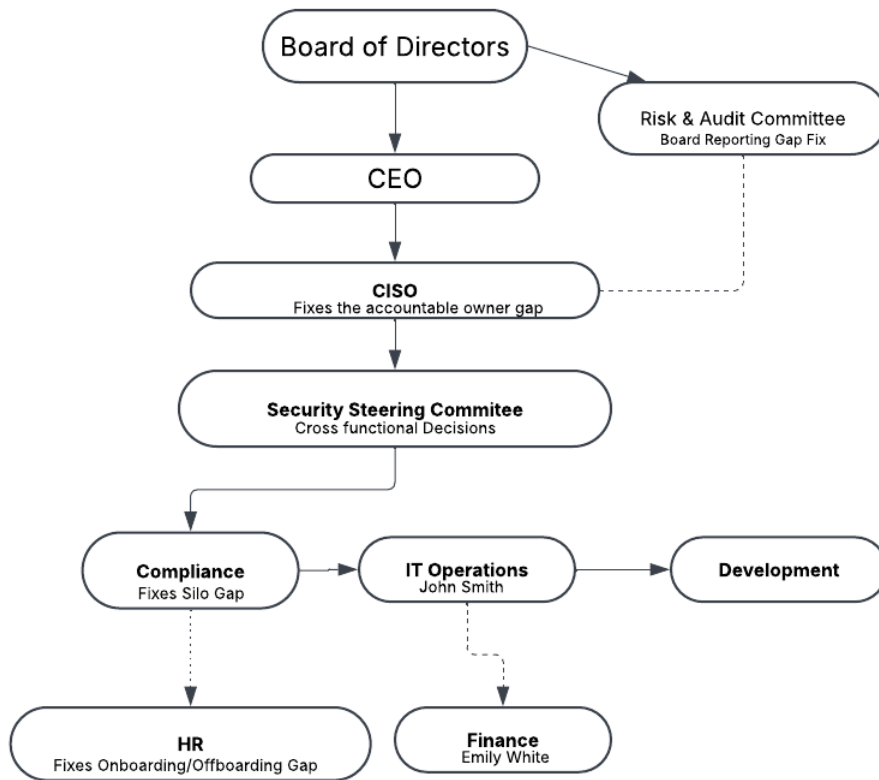
| Student Information |                               |
|---------------------|-------------------------------|
| Full Name           | Khodani Netshifhefhe          |
| Registration Number | C11/26/CGRCE/17580            |
| Email Address       | c11.cgrce2617580@icdfa.edu.ng |
| Submission Date     | 11 September 2026             |

## Task 1 Governance Blueprint

### 1. Current-state governance gap assessment for GHC adhoc

| Gap Found                                                       | Gap Analysis                                                                                                                                                                                                                                         |
|-----------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| No single accountable owner for security                        | No one holds formal, board-recognised accountability for the security programme as a whole. John Smith manages infrastructure and performs <b>some</b> security activities.                                                                          |
| Compliance is siloed from operational security.                 | There is no evidence of a structural link between Mark the Compliance officer in Legal and compliance with the technical/operational security decisions made by IT and Development                                                                   |
| HR processes are not integrated into the security lifecycle     | There is no evidence of collaboration between HR and Security Team on both onboarding and Offboarding processes                                                                                                                                      |
| No formal risk management or Board reporting process.           | The Board currently has no structured visibility into the organisation's security posture.                                                                                                                                                           |
| Inconsistent, inherited policy base                             | Two acquisitions mean GHC likely operates on two or three different legacy policy sets with no merging process. This leaves employees governed by conflicting rules.                                                                                 |
| No cross-functional decision-making forum for security matters. | No forum exists for IT, Development, Compliance, Finance, and HR to jointly weigh security decisions. Departments act in isolation, so disputes like the current CTO/IT Manager disagreement over password policy have no defined path to resolution |

### 2. A proposed security governance organisational chart



By Khodani Netshifhefhe

### 3. A RACI matrix covering at least six governance activities

**R** = Responsible, **A** = Accountable, **C** = Consulted, **I** = Informed

| Governance Activity                                        | Board | CEO | CISO | Security Steering Committee | Compliance | IT/OPS | HR |
|------------------------------------------------------------|-------|-----|------|-----------------------------|------------|--------|----|
| Approve security policy                                    | I     | A   | R    | C                           | C          | C      | I  |
| Risk review & risk register                                | I     | A   | R    | C                           | C          | C      | I  |
| Incident response planning                                 | I     | A   | R    | I                           | C          | R      | C  |
| Board security reporting                                   | A     | R   | R    | I                           | C          | I      | I  |
| Cross-functional dispute resolution (e.g. password policy) | I     | I   | R    | A                           | C          | C      | I  |

|                                       |   |   |   |   |   |   |   |
|---------------------------------------|---|---|---|---|---|---|---|
| Joiner/mover/leaver<br>access control | I | A | C | I | I | R | R |
|---------------------------------------|---|---|---|---|---|---|---|

#### 4. How the proposed structure supports accountability, transparency, business alignment and risk management

Accountability is established by naming a single owner. The CISO, reporting to the CEO creates a clear ownership of every governance activity, instead of leaving responsibility spread across IT Operations. With the RACI matrix, roles and responsibilities are clearly mapped out from the top down. All business units including HR processes and compliance are well integrated into the security and business role. It supports business alignment by making the Security Steering Committee the place where security decisions get weighed against business priorities, rather than one department deciding alone

## Task 2 Information Security Charter

#### 5. Completed GHC Information Security Charter.

##### Purpose

The Information Security Programme is developed to protect GlobalHealth Connect's patient data, systems and reputation whilst enabling the business to grow safely. It supports GHC's 2026 strategic goals by making security a business enabler rather than a barrier. It protects customer trust, supporting regulatory adherence, and giving the CEO, CFO and Board the confidence to pursue market expansion and innovation without out of balance risk.

##### Scope

This Charter applies to all GHC systems, infrastructure, applications and data including patient information, financial data and intellectual property whether hosted internally or by third parties. It covers all employees, contractors and third-party vendors, and extends to all entities and systems brought in through acquisitions, until fully integrated under GHC's unified security policies.

##### Authority

This Charter is issued under the authority of the Board of Directors and CEO. It gives the Chief Information Security Officer (CISO) the authority to set security policy, standards and controls across GHC, to require remediation of identified risks, and to escalate unresolved risks directly to the CEO or Board Risk & Audit Committee. Disputes between business functions over security requirements are escalated to the Security Steering Committee for resolution unresolved disputes escalate to the CEO.

## **Roles and Responsibilities**

High-level accountabilities

Board of Directors - ultimate oversight; approves the Charter and receives regular security reporting.

CEO - accountable for the overall Information Security Programme.

CISO - responsible for day-to-day programme execution, policy, risk management and incident response.

Security Steering Committee - resolves cross-functional security decisions and disputes.

Compliance - ensures regulatory obligations are reflected in security controls.

IT Operations, Development, Finance, HR - implement security controls within their functions, including access management across the employee lifecycle.

## **Key Principles**

Risk-based - security effort is prioritised according to actual risk to patients, data and the business, not applied uniformly.

Business aligned - security decisions support, rather than obstruct, GHC's strategic goals.

Proportionate - controls are matched to the sensitivity of the data and system involved.

Continuous improvement - the programme matures over time rather than remaining static

## **Reporting Structure**

The CISO reports operationally to the CEO and provides quarterly reports to the Board Risk & Audit Committee covering security posture, key risks and incident trends. The Security Steering Committee meets regularly to review cross-functional issues and reports outcomes to the CEO. Significant incidents are reported to the CEO immediately and to the Board at the next scheduled meeting or sooner if material.

## Review and Approval

This Charter is approved by the CEO and Board of Directors. It is reviewed annually, or sooner following a material incident, significant organisational change (such as an acquisition), or a material change in regulatory requirements. Amendments require CEO approval and are reported to the Board.

### **6. Justification memo to Marcus Thorne, CFO, explaining how the Charter supports GHC's strategic goals, accountability and investment decisions**

The attached Information Security Charter gives GHC's security programme the formal mandate it been missing initially. It supports our 2026 strategic goals by establishing clear ownership, decision authority and escalation paths. The Charter protects the "Maintain Customer Trust" goal reducing the likelihood of a breach that would damage GHC's reputation during a critical growth period while also supporting "Achieve Regulatory Excellence" by linking Compliance directly into security decision making rather than leaving it siloed. For "Expand Market Share" and "Foster Innovation," the Charter's risk-based, proportionate approach means security won't act as a blanket brake on new features or regional expansion; instead, effort is prioritised where risk is genuinely material, allowing the business to move quickly where it's safe to do so.

From an investment perspective, the Charter creates the accountability structure needed to justify and track security spend. Every amount invested in the programme now maps to a named owner, the CISO and a defined reporting line to the Board, meaning future security budget requests can be tied to specific risks and measurable outcomes rather than ad hoc requests. This also reduces enterprise risk exposure and by extension, the cost of capital and insurance premiums that scale with GHC's perceived security maturity making the Charter a foundation for disciplined, defensible investment decisions rather than a compliance formality.

## Task 3 Board Reporting and Security Metrics

### **7. A one-page Board Executive Summary containing an overall Red/Amber/Green posture assessment and justification.**

**RED**, with justification of rising high-risk incidents, declining patch rate against growing vulnerability volume.

## Task 4 Security Steering Committee

### 8. Security Steering Committee Terms of Reference

#### Purpose

The Security Steering Committee (SSC) exists to make cross-functional security decisions that balance risk, usability and business priorities, and to resolve disputes between functions such as IT Operations and Development/Technology where security requirements conflict with operational or product needs.

#### Scope

The SSC governs security policy decisions, control trade-offs, and cross-functional disagreements affecting more than one business function. It does not cover day-to-day operational security tasks, which remain the responsibility of IT Operations and the CISO's team.

#### Membership

- CISO (Chair)
- CTO (Elena Rodriguez)
- IT Manager (John Smith)
- Compliance Officer (Mark Johnson)
- A rotating business representation

#### Responsibilities

- Review and approve significant security policy changes before organisation-wide rollout.
- Resolve disputes between functions over security control design.
- Evaluate trade-offs between security strength, usability and cost.
- Escalate unresolved issues to the CEO.

#### Meeting Cadence

Monthly as standing practice, with ad hoc sessions convened within five business days

when a cross-functional conflict requires timely resolution (as with the current password-policy dispute).

### Decision Authority

The SSC has authority to approve or reject proposed security policies and controls by majority agreement among voting members (CISO, CTO, IT Manager, Compliance). Where no majority is reached, or a decision carries material business risk, the matter escalates to the CEO for final decision.

### Reporting

The SSC reports decisions and outstanding issues to the CEO after every meeting, and provides a quarterly summary to the Board via the CISO's regular reporting line.

### 9. Sample Agenda

| Item                                                              | Speaker    | Time (Minutes) |
|-------------------------------------------------------------------|------------|----------------|
| 1. Welcome and Purpose                                            | CISO       | 5              |
| 2. Password Policy Dispute                                        | IT Manager | 15             |
| 3. Discussion and decision on password policy direction           | Everyone   | 15             |
| 4. Review of open security risks requiring cross-functional input | CISO       | 10             |
| 5. Confirm next meeting and any escalationa                       | CISO       | 10             |
| 6. Close                                                          | Everyone   | 5              |

## Task 5 Governance Maturity Assessment

14. A completed maturity assessment for Policy & Documentation, Roles & Responsibilities, Risk Management, Metrics & Reporting, Training & Awareness, and Compliance.

| Governance Domain        | Current Level | Justification                                                                                                                                             |
|--------------------------|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|
| Policy & Documentation   | 2 – Initial   | Policies exist but are inconsistent, inherited from acquisitions, and not consistently kept current some documentation exists, but it isn't standardised. |
| Roles & Responsibilities | 1 – Ad Hoc    | No clear ownership or accountability for security exists anywhere in the organisation; this is the most informal of all domains.                          |
| Risk Management          | 1 – Ad Hoc    | The organisation is reactive with no formal, proactive risk assessment process the defining characteristic of Level 1.                                    |
| Metrics & Reporting      | 2 – Initial   | Technical metrics are collected some process exists but aren't translated into business terms, so they aren't yet standardised for decision-making.       |
| Training & Awareness     | 2 – Initial   | A documented process exists (mandatory annual training), but low engagement shows it isn't yet effectively applied or embedded.                           |
| Compliance               | 2 – Initial   | A process exists (audits happen) but it's periodic and reactive rather than continuous, so it isn't yet a standardised, ongoing practice.                 |

#### 15. 12–18 Month Maturity Roadmap